



NOMBRE: Alexander Ramon de la Cruz Reyes

MATRICULA: 2025-2176

CARRERA: Seguridad Informática

MATERIA: Seguridad de Redes

DOCENTE: Jonathan Rondon

FECHA:25/9/2025

Introducción

En este laboratorio se buscó construir una infraestructura pequeña, pero organizada como una red real. La idea no fue conectar los equipos únicamente para obtener respuesta entre ellos, sino separar las funciones y decidir de forma consciente qué comunicación debía estar permitida. Por esa razón, el cliente, el servidor web y el servidor de base de datos se encuentran en segmentos diferentes y el tráfico entre ellos pasa por controles definidos en FortiGate.

FortiGate funciona como el punto central de seguridad, mientras que el switch mantiene la separación lógica mediante VLAN. Esta combinación permitió trabajar con una estructura sencilla de entender, pero suficientemente completa para aplicar controles de acceso, inspección, filtrado y restricciones entre servicios. Durante la práctica se buscó que cada decisión tuviera un propósito claro y que las pruebas finales permitieran comprobar el efecto real de las reglas configuradas.

Propósito del laboratorio

El propósito principal es demostrar de forma práctica cómo la segmentación y las políticas de seguridad ayudan a reducir la exposición dentro de una red. En lugar de permitir que todos los equipos se comuniquen libremente, se habilitaron únicamente los servicios necesarios para el funcionamiento del laboratorio. Esto incluye acceso HTTPS hacia el servidor web, restricción del acceso directo a la base de datos, comunicación controlada entre WEB-SERVER y DB-SERVER, inspección del tráfico y medidas básicas de protección en el switch.

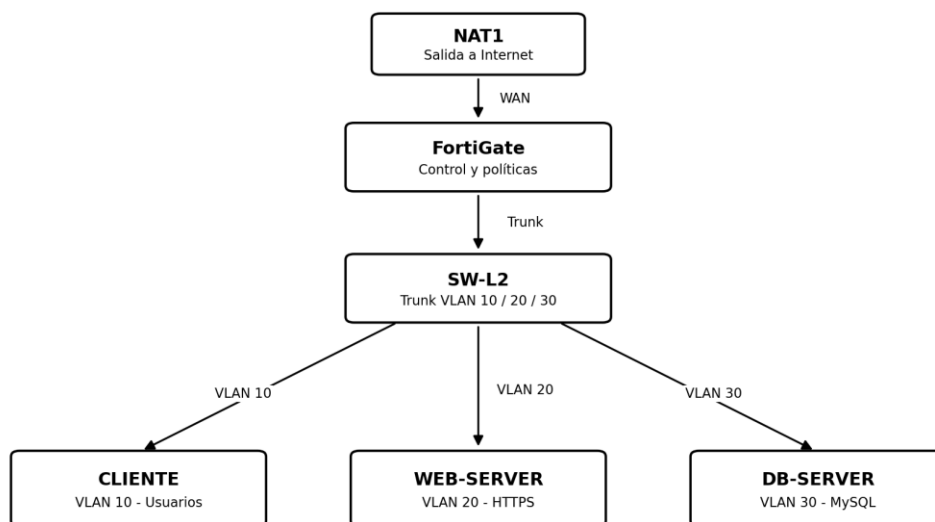
También se incorporaron controles complementarios como NAT para la salida de los usuarios, inspección profunda, un perfil IPS orientado a patrones relacionados con SQL Injection, filtrado de archivos ejecutables y limitación de tráfico. El objetivo de reunir estos mecanismos en una misma práctica fue observar cómo distintas capas de seguridad pueden trabajar juntas y no depender de una sola regla o dispositivo.

Diseño de la infraestructura

La infraestructura se organizó alrededor de un FortiGate conectado a la salida de Internet y a un switch de capa 2. Desde el switch se conectan tres equipos con funciones distintas: un cliente que representa a los usuarios, un servidor web y un servidor de base de datos. Cada función se mantiene en una VLAN separada, de modo que el tráfico entre segmentos debe pasar por las políticas configuradas en FortiGate antes de llegar a su destino.

Figura 1

Diagrama lógico de la infraestructura

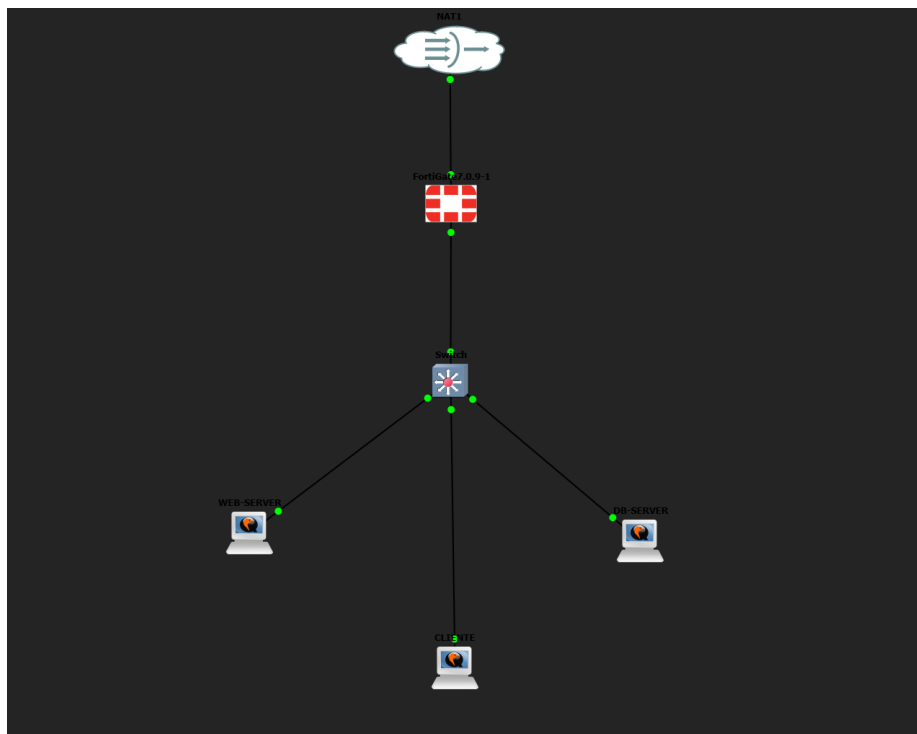


Segmentación: usuarios, servidor web y base de datos en redes separadas

Nota. Diagrama simplificado de la infraestructura. Se muestra la salida a Internet, FortiGate como punto de control, el enlace troncal hacia el switch y la separación de CLIENTE, WEB-SERVER y DB-SERVER por VLAN.

El diagrama resume la lógica del laboratorio sin entrar en detalles innecesarios de direccionamiento. Lo más importante es observar que los tres tipos de equipos no se encuentran en una misma red y que FortiGate queda ubicado en el camino de las comunicaciones entre segmentos.

Figura 2
Topología implementada en GNS3



Nota. Captura de la topología utilizada durante la práctica. Se observan NAT1, FortiGate, el switch, WEB-SERVER, DB-SERVER y CLIENTE conectados según el diseño planteado.

Esta vista corresponde a la implementación real en GNS3. Mantener una topología sencilla facilitó identificar el origen y destino de cada prueba, además de comprobar con mayor claridad qué política debía intervenir en cada comunicación.

Segmentación e interfaces de FortiGate

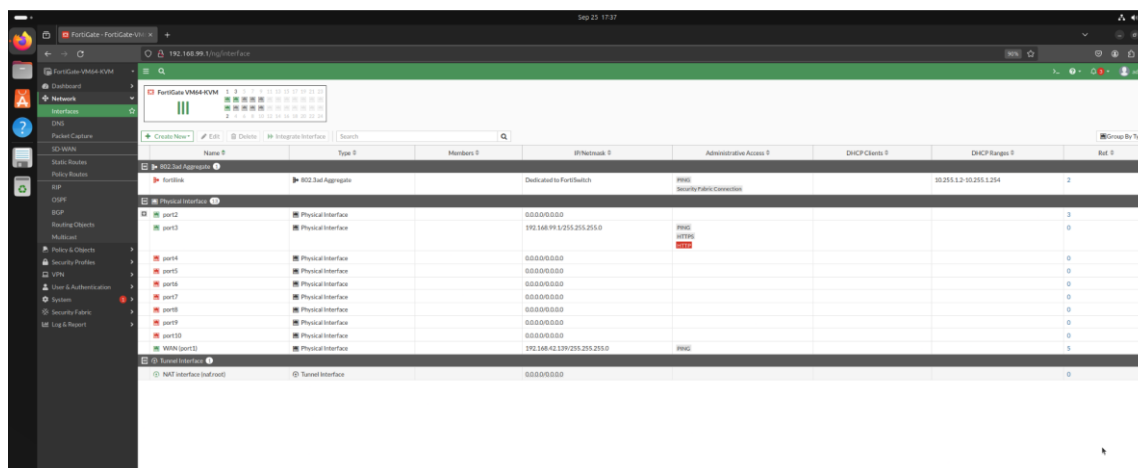
La separación de la infraestructura se realizó mediante tres VLAN: una destinada a los usuarios, otra al servidor web y otra al servidor de base de datos. La red de usuarios utiliza DHCP para recibir su configuración de forma automática, mientras que los servidores permanecen en sus segmentos correspondientes. Esta organización evita que funciones distintas compartan el mismo dominio lógico y hace posible aplicar políticas específicas según el origen y el destino del tráfico.

Desde el punto de vista práctico, la segmentación fue una de las partes más importantes del laboratorio. Antes de pensar en IPS, filtrado o limitación de tráfico, era

necesario lograr que cada equipo perteneciera al segmento correcto. De esta forma, FortiGate puede evaluar las comunicaciones entre redes y decidir qué debe permitirse o bloquearse.

Figura 3

Vista de interfaces en FortiGate



Nota. Evidencia de la interfaz gráfica de FortiGate utilizada para revisar y administrar las interfaces y segmentos de la práctica.

Políticas de acceso y control del tráfico

Las políticas del firewall definen de manera directa qué comunicaciones forman parte del funcionamiento normal de la infraestructura. Los usuarios cuentan con una política de salida hacia Internet con NAT y una regla específica para llegar al servidor web mediante HTTPS. En cambio, el acceso directo de los usuarios al servidor de base de datos mediante MySQL se mantiene bloqueado, evitando una comunicación que no es necesaria desde la red de usuarios.

La comunicación entre los dos servidores también se limita. WEB-SERVER puede comunicarse con DB-SERVER mediante MySQL por el puerto 3306, pero una regla posterior bloquea otros servicios entre ambos segmentos. Esta decisión sigue el principio de permitir únicamente lo necesario: el servidor web conserva el servicio que requiere para trabajar con la base de datos, sin dejar abiertos otros puertos que no forman parte del objetivo del laboratorio.

Figura 4
Políticas de firewall configuradas

Name	Source	Destination	Schedule	Service	Action	NAT	Security Profiles	Log	Bytes
DB-INTERNET	DB-SERVER	all	always	all	ACCEPT	Enabled	no inspection	AI	253.26 MB
USUARIOS-DB-BLOQUEO	USUARIOS	DB-SERVER	always	MYSQL-3306	DENY	Disabled	no inspection	Disabled	0B
USUARIOS-INTERNET	USUARIOS	all	always	all	ACCEPT	Enabled	Deep-Inspection	AI	28.39 MB
USUARIOS-WEB-HTTPS	USUARIOS	WEB-SERVER	always	HTTPS	ACCEPT	Disabled	IPS-SQLI-WEB	AI	0B
WEB-DB-MYSQL	WEB-SERVER	DB-SERVER	always	MYSQL-3306	ACCEPT	Disabled	no inspection	AI	210 B
WEB-DB-BLOQUEO	WEB-SERVER	DB-SERVER	always	all	DENY	Disabled	no inspection	Disabled	1.48 KB
WEB-INTERNET	WEB-SERVER	all	always	DNS, HTTP, HTTPS	ACCEPT	Enabled	Deep-Inspection	AI	137.72 MB

Nota. La vista muestra las reglas principales entre usuarios, servidor web, servidor de base de datos e Internet. También se observan perfiles de seguridad asociados a algunas políticas.

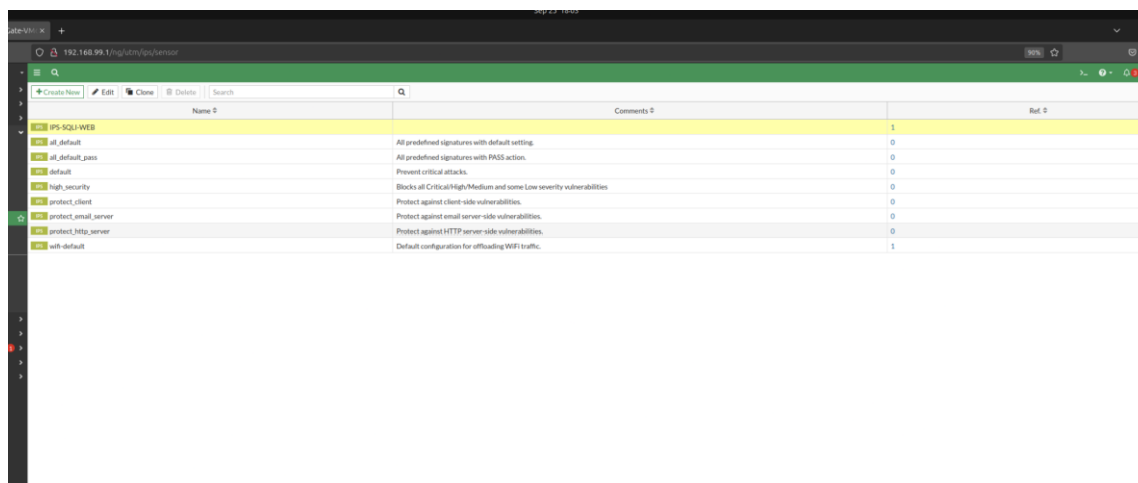
La vista general de políticas permite comprobar rápidamente la intención del diseño: existen reglas de aceptación para los servicios necesarios y reglas de denegación para comunicaciones que se desean restringir. Además, se observan perfiles de inspección asociados a las políticas que requieren un análisis adicional del tráfico.

Inspección y protección del servidor web

Para complementar las reglas de acceso, la política que comunica a los usuarios con el servidor web utiliza inspección profunda y un perfil IPS denominado IPS-SQLI-WEB. La finalidad de este perfil es añadir una capa de revisión sobre el tráfico que llega al servicio web y permitir la detección de patrones definidos para intentos de SQL Injection.

El IPS no sustituye la segmentación ni las reglas del firewall. Primero se determina si una comunicación puede existir y, cuando corresponde, los perfiles de seguridad analizan el contenido del tráfico con mayor detalle. En este laboratorio se trabajó con ese enfoque por capas: segmentar, limitar los servicios permitidos y luego agregar inspección sobre el tráfico autorizado.

Figura 5
Sensor IPS utilizado en la práctica



Name	Comments	Ref.
IPS-SQLI-WEB		1
all_default	All predefined signatures with default setting.	0
all_default_pass	All predefined signatures with PASS action.	0
default	Prevent critical attacks.	0
high_security	Blocks all Critical/High/Medium and some Low severity vulnerabilities.	0
protect_client	Protect against client-side vulnerabilities.	0
protect_email_server	Protect against email server-side vulnerabilities.	0
protect_http_server	Protect against HTTP server-side vulnerabilities.	0
web-default	Default configuration for offloading Web traffic.	1

Nota. Captura del listado de sensores IPS de FortiGate, donde se observa el perfil IPS-SQLI-WEB creado para la práctica.

Filtrado de archivos y limitación de tráfico

En la navegación de los usuarios se aplicó el perfil BLOQUEO-EXE para impedir descargas de archivos ejecutables según las reglas definidas en el filtro. Este control se planteó como una medida adicional para reducir la posibilidad de que un usuario descargue directamente un archivo potencialmente riesgoso desde la navegación web.

También se configuró una limitación de ancho de banda mediante LIMIT-USUARIOS y RATE-LIMIT-USUARIOS. El propósito no es impedir el uso normal de la red, sino establecer un límite que ayude a controlar consumos excesivos y reduzca el impacto de situaciones de saturación. Con esto se complementan las políticas de acceso con un control sobre el volumen de tráfico.

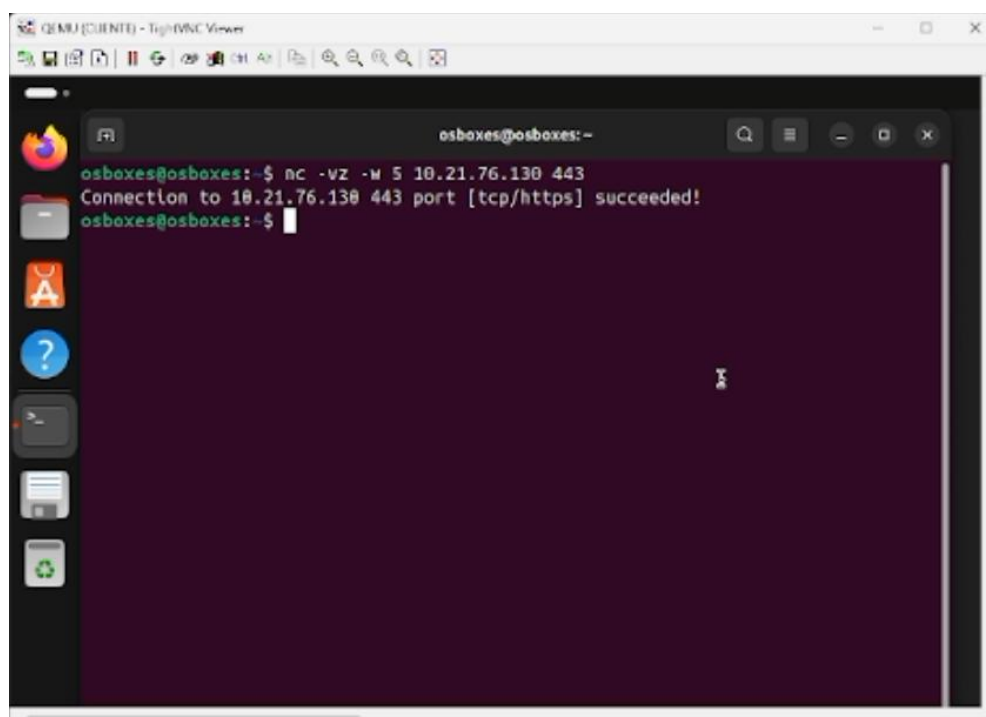
Comprobaciones de funcionamiento

Las pruebas se realizaron desde los propios equipos de la topología para confirmar que las políticas tuvieran un efecto real y no fueran únicamente configuraciones visibles en la interfaz. Se seleccionaron pruebas simples y directas: una comunicación permitida debía establecerse correctamente y una comunicación restringida debía fallar o expirar.

La primera comprobación se realizó desde el CLIENTE hacia el WEB-SERVER utilizando el puerto 443. El resultado fue exitoso, lo que coincide con la política que permite a los usuarios acceder al servidor web mediante HTTPS. Esta prueba es importante porque confirma que la segmentación no bloquea el servicio legítimo que sí debe estar disponible para los usuarios.

Figura 6

Acceso del CLIENTE al WEB-SERVER mediante HTTPS

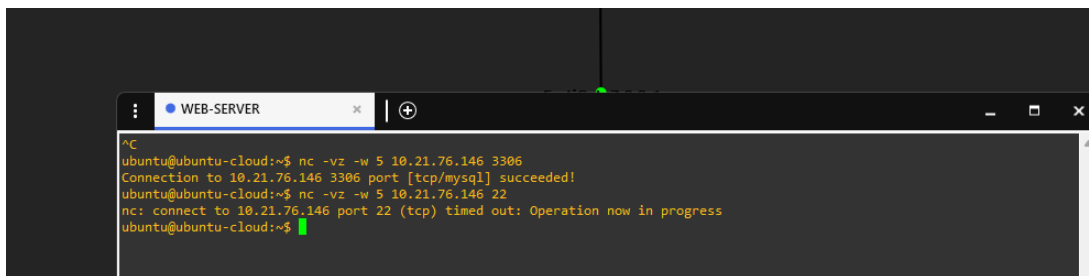


Nota. La conexión TCP desde el CLIENTE hacia el WEB-SERVER por el puerto 443 fue exitosa. El resultado coincide con la política que permite HTTPS desde la red de usuarios hacia el servidor web.

La segunda comprobación se realizó desde WEB-SERVER hacia DB-SERVER. El puerto MySQL 3306 logró establecer conexión, mientras que un intento por TCP/22 expiró. Al comparar ambos resultados se puede observar claramente el comportamiento esperado: el servicio necesario permanece disponible y un puerto distinto queda restringido.

Figura 7

Prueba de comunicación entre WEB-SERVER y DB-SERVER



```
^C
ubuntu@ubuntu-cloud:~$ nc -vz -w 5 10.21.76.146 3306
Connection to 10.21.76.146 3306 port [tcp/mysql] succeeded!
ubuntu@ubuntu-cloud:~$ nc -vz -w 5 10.21.76.146 22
nc: connect to 10.21.76.146 port 22 (tcp) timed out: Operation now in progress
ubuntu@ubuntu-cloud:~$
```

Nota. La conexión al puerto MySQL 3306 fue exitosa, mientras que el intento por TCP/22 expiró. El resultado coincide con la política que permite MySQL y bloquea otros servicios entre ambos segmentos.

Estas comprobaciones muestran que las reglas no se limitaron a existir dentro de FortiGate, sino que afectaron de manera concreta el tráfico entre los equipos. El laboratorio conserva la conectividad necesaria para operar, pero evita comunicaciones que no forman parte del diseño.

Seguridad del switch

El switch cumple una función esencial en la segmentación porque es el punto donde se conectan los equipos finales. Se configuraron las VLAN correspondientes a usuarios, WEB y DB, y el enlace hacia FortiGate trabaja como trunk para transportar las VLAN requeridas. Los puertos conectados a los equipos finales funcionan como puertos de acceso en su VLAN correspondiente, evitando que un mismo puerto forme parte de segmentos que no le pertenecen.

Como medida adicional se aplicó Port Security en los puertos de acceso y se deshabilitaron los puertos que no se utilizan. Estas configuraciones ayudan a reducir conexiones no previstas y complementan las políticas de FortiGate. Aunque el firewall concentra gran parte del control, la seguridad también debe comenzar desde la capa de acceso, donde físicamente se conectan los dispositivos.

Conclusión

La infraestructura implementada demuestra que incluso una red pequeña puede organizarse de forma más segura cuando cada función se mantiene en su propio segmento y la comunicación se limita a lo realmente necesario. FortiGate concentra las políticas de acceso y los perfiles de inspección, mientras que el switch mantiene la separación lógica mediante VLAN y controles de capa 2.

Durante la práctica se comprobó que la seguridad no depende de una única configuración. La segmentación, las reglas de firewall, la inspección, el filtrado y las restricciones del switch se complementan entre sí. Las pruebas realizadas confirmaron que el CLIENTE puede acceder al servidor web mediante HTTPS y que WEB-SERVER puede utilizar MySQL hacia DB-SERVER, mientras que un puerto diferente queda bloqueado. En conjunto, el resultado cumple con la intención del laboratorio: mantener disponibles los servicios necesarios y reducir accesos que no aportan al funcionamiento de la infraestructura.